DIGITAL FORENSICS & CYBER SECURITY BOOTCAMP — WEEKEND 3, DAY 5

Web Application Penetration Testing & Reconnaissance

Trainer / Lead Specialist:	Waseem Abbas Khan (Senior Cybersecurity Specialist, CEI Master Trainer)
Target Enterprise Domain:	NUEXUS Technologies (Private) Limited — Domain: *.nuexus.com
Testing Operator:	Muhammad Zahid (Security Analyst & Penetration Testing Operator)
Technical Platform:	Kali Linux 2026.3 Rolling / BlackArch Linux / Burp Suite Pro / OWASP ZAP

1. Executive Summary & Context

Modern web application penetration testing focuses on the application layer (TCP 443 HTTPS), evaluating dynamic endpoints, client-side virtual DOM interactions, authentication mechanisms, and API backends. Scanning a single port reveals minimal information; comprehensive security insight emerges from dissecting client-server transactions and multi-source reconnaissance. This deliverable fulfills the four required technical mandates of Day 5 against the authorized production domain **nuexus.com**.

2. Task 1: Scope Definition & Rules of Engagement (Weight: 25%)

A rigorous scope document defines the boundary between authorized security analysis and computer intrusion. The boundaries and exclusions for *.nuexus.com are structured as follows:

Asset / Target Host	Classification	Operational Boundary & Rules
https://www.nuexus.com	In-Scope (Primary)	Full crawl, passive audit, manual parameter fuzzing in Repeater.
https://app.nuexus.com	In-Scope (Portal)	Grey-box access with test credentials; authorization boundary checks.
https://api.nuexus.com	In-Scope (API)	REST API fuzzing, endpoint enumeration, CORS policy verification.
*.nuexus.com (Subdomains)	In-Scope (Conditional)	Enumerated hosts subject to mandatory Break-Glass Verification.
career.nuexus.com	Strictly Out-of-Scope	Explicitly excluded HR portal; zero automated or manual packets.
Cloudflare & Vercel Infra	Strictly Out-of-Scope	Shared multi-tenant infrastructure; zero DoS, volumetric scans.
Employee Personal Devices	Strictly Out-of-Scope	Zero phishing, social engineering, or personal account targeting.

THE WILDCARD BREAK-GLASS CLAUSE: Wildcard scopes (*.nuexus.com) present legal risks because subdomains may route to unmaintained third-party SaaS tenants. Whenever a new host is discovered, testing is frozen until ownership is verified via DNS records and authorized in writing by Technical Authority Waseem Abbas Khan. Emergency halt code: *ABORT-NUEXUS-ALPHA-STOP*.

3. Task 2: Google Dorking Vulnerability Assessment (Weight: 25%)

Google Dorking interrogates public search engine indices to uncover exposed documents, subdomains, and misconfigurations passively without transmitting packets to the target organization. Six targeted queries were evaluated:

Dork Query	Finding Status	Defensive Control / Remediation
site:nuexus.com	EXPOSURE: Corporate emails (info@nuexus.com) and phone numbers indexed.	Maintain centralized aliases; sanitize direct contact data.
site:nuexus.com filetype:pdf	EXPOSURE: 5+ internal technical playbooks indexed under /playbooks/.	Apply X-Robots-Tag: noindex or restrict playbooks behind auth.
site:nuexus.com intitle:"index of"	CLEAN: Directory browsing disabled across all servers.	Retain Options -Indexes across all web roots.
site:nuexus.com inurl:admin OR inurl:login	CLEAN: Administrative panels excluded from search index.	Maintain SSO, IP whitelisting, and noindex headers.
site:nuexus.com ext:env OR ext:conf	CLEAN: Zero secrets, configs, or logs indexed.	Enforce strict repository .gitignore rules.
site:nuexus.com -www	EXPOSURE: Discovered production portal app.nuexus.com.	Verify indexation intent; configure robots.txt appropriately.

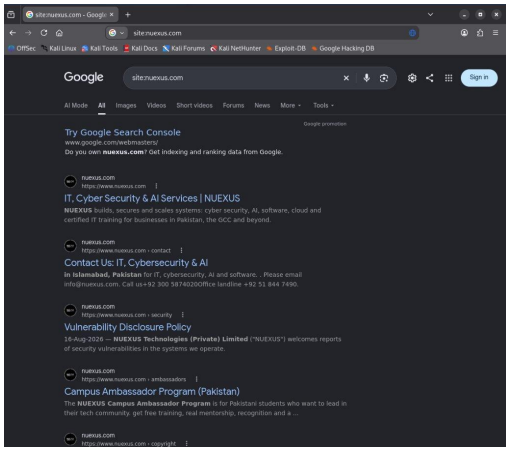


Figure 2.1: Baseline Google Dork (site:nuexus.com) exposing corporate contact data.

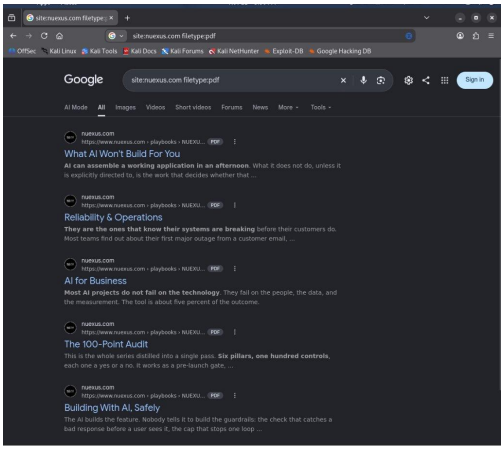


Figure 2.2: Document exposure dork discovering 5+ proprietary playbooks.

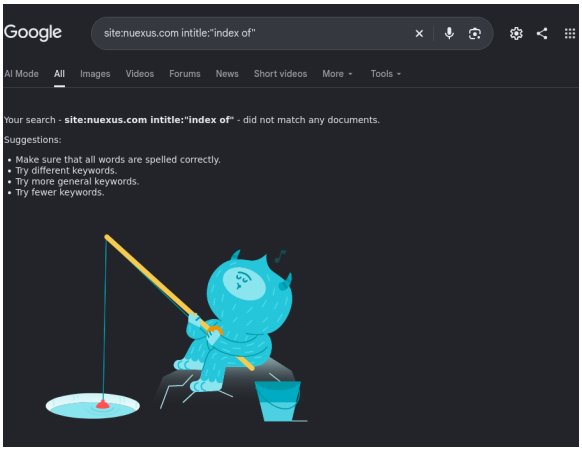


Figure 2.3: Verification of directory browsing protection (clean result).

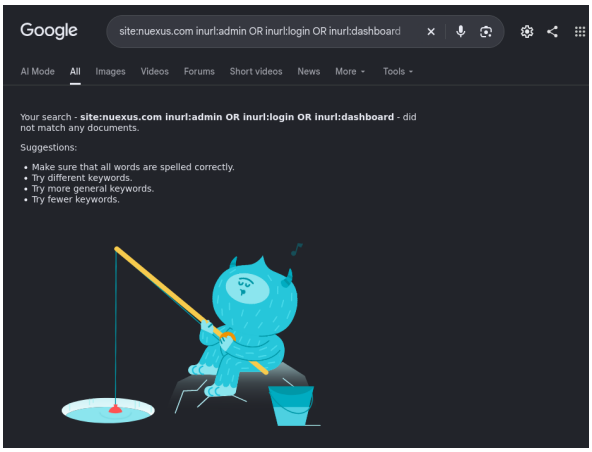


Figure 2.4: Administrative interface search confirming clean exposure status.

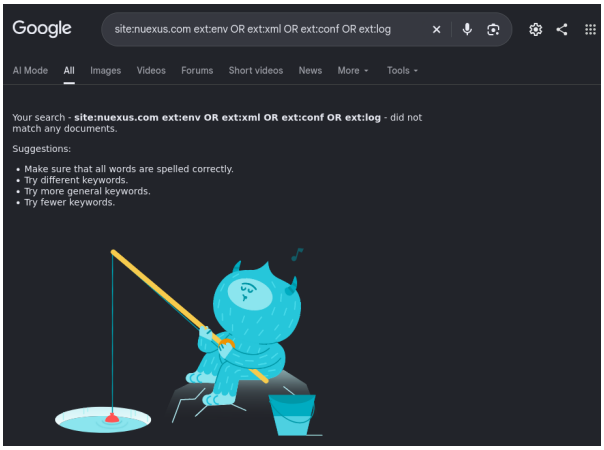


Figure 2.5: Configuration file check confirming absence of exposed .env files.

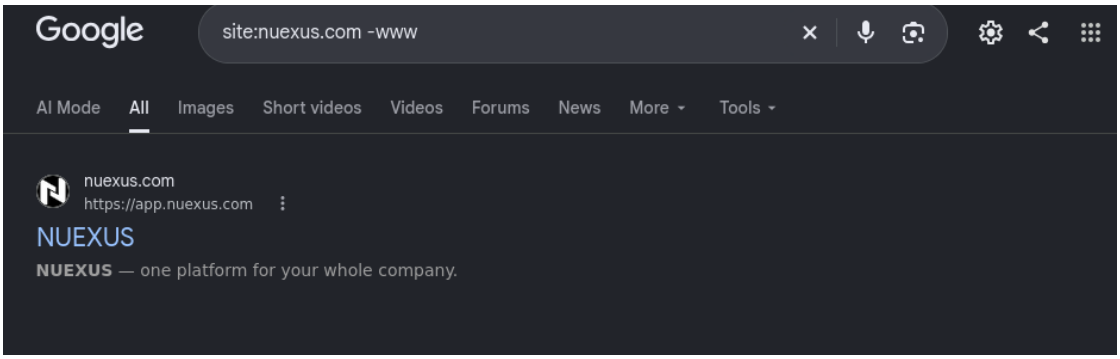


Figure 2.6: Exclusion dork isolating the active application portal app.nuexus.com.

4. Task 3: Multi-Engine Subdomain Reconnaissance & Reconciliation (Weight: 25%)

Subdomain enumeration identifies development branches, staging hosts, and internal portals. Three tools were executed: **subfinder** (24 hosts via CT logs), **assetfinder** (7 core production hosts), and **theHarvester** (20 hosts + 10 IPs). All candidates were deduplicated into subs.txt and actively resolved with **httpx-toolkit**:

FQDN Subdomain	Resolved IP	Status	Detected Stack	Security Observation
https://nuexus.com	172.67.201.8	308 Redirect	Cloudflare, Vercel, HSTS	Permanent edge redirect to www.
https://www.nuexus.com	188.114.97.6	200 OK	Cloudflare, Vercel, Next.js	Primary corporate landing portal.
https://app.nuexus.com	104.21.85.21	200 OK	Bootstrap, Google Sign-in	Production application portal.
https://autodiscover.nuexus.com	104.21.85.21	200 OK	Google Cloud CDN, HSTS	Mail client autodiscovery service.
https://autoconfig.nuexus.com	188.114.97.6	200 OK	Google Cloud CDN, HSTS	Email autoconfig active daemon.
https://mta-sts.nuexus.com	76.76.21.61	200 OK	Vercel Edge, HSTS	Strict Transport Security mail policy.
https://recruit.nuexus.com	104.21.85.21	526 SSL Err	Cloudflare, HTTP/3	Origin SSL certificate invalid/expired.
https://assessments.nuexus.com	188.114.97.6	526 SSL Err	Cloudflare, HTTP/3	Origin SSL handshake failed.
https://api.nuexus.com	188.114.97.6	526 SSL Err	Cloudflare, HTTP/3	Backend API origin SSL invalid.

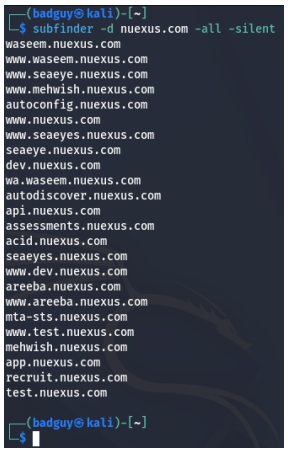


Figure 3.1: Subfinder enumeration output identifying 24 subdomains.

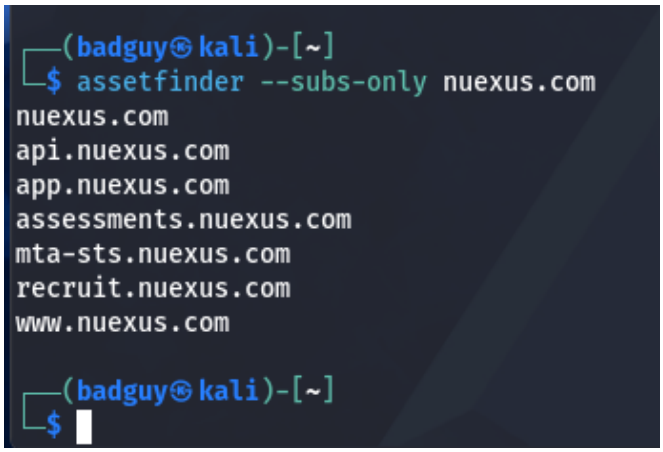


Figure 3.2: Assetfinder execution capturing 7 primary active hosts.

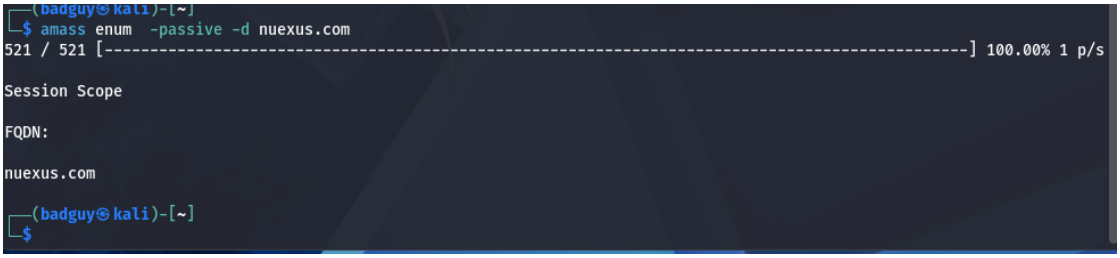


Figure 3.3: Amass baseline query showing session scope bounds.

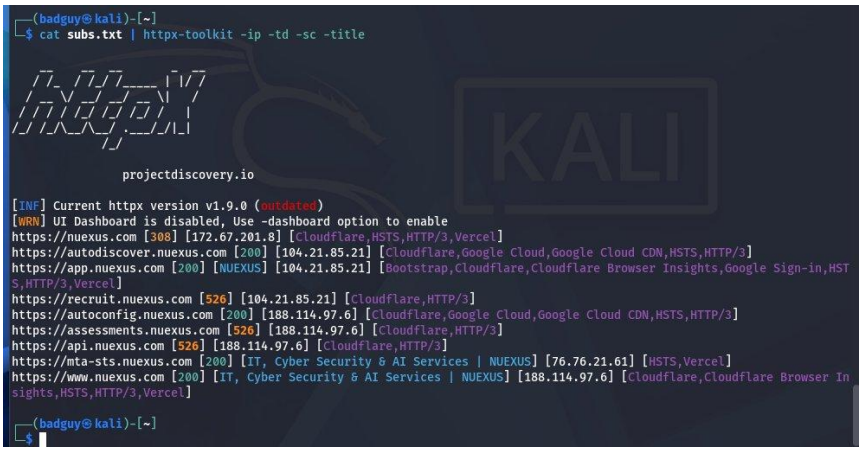


Figure 3.4: Active host probe via httpx-toolkit validating live services and HTTP 526 SSL errors.

5. Task 4: Automated Web Scanner Comparative Analysis (Weight: 25%)

Burp Suite Professional/Community and OWASP ZAP were evaluated concurrently against https://www.nuexus.com. The scanners exhibited distinct strengths based on their architectural designs:

Comparison Dimension	Burp Suite (Pro / Community)	OWASP ZAP (Checkmarx)
Crawl Mechanism	Manual proxy browsing + Chromium crawler.	Traditional link spider + Firefox Headless AJAX spider.
Modern SPA Handling	Inspects static response bodies and manual paths.	Dynamically executes JavaScript in real browser runtime.
Vulnerability Engine	Heuristic regex matching and passive header audit.	Active DOM taint analysis (source-to-sink tracking).
Findings Summary	12 Issues (0 High, 0 Med, 1 Low, 11 Info).	47 Alerts (6 High, 9 Med, 5 Low, 27 Info).
Unique Findings	Granular Next.js chunk IDs, API route modeling, CORS wildcard.	DOM XSS (innerHTML), prototype pollution, DOM taint flows.

Why ZAP Detected 47 Alerts While Burp Detected 12: OWASP ZAP utilized its Headless Firefox AJAX Spider, crawling 195 URLs and executing client-side Next.js code dynamically. This allowed its taint engine to detect 6 High-Severity DOM XSS vulnerabilities where user input flowed into sinks like Element.innerHTML. Burp Suite operated as a passive proxy auditor during manual navigation; it identified systemic response misconfigurations (CSP 'unsafe-inline', wildcard CORS on OPTIONS preflight) but did not execute client taint-tracking.

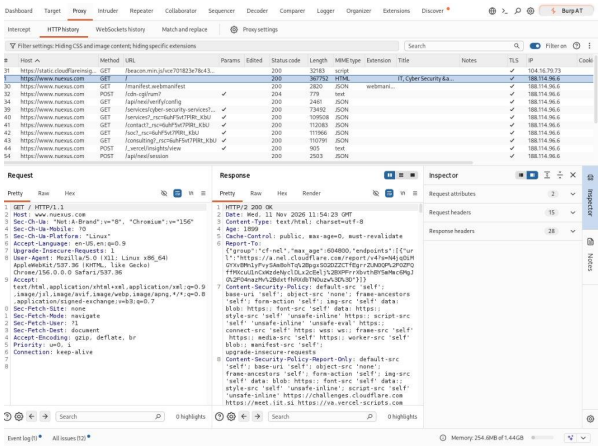


Figure 4.1: Client-server request/response model inspection in Burp Proxy HTTP history (Outcome #1).

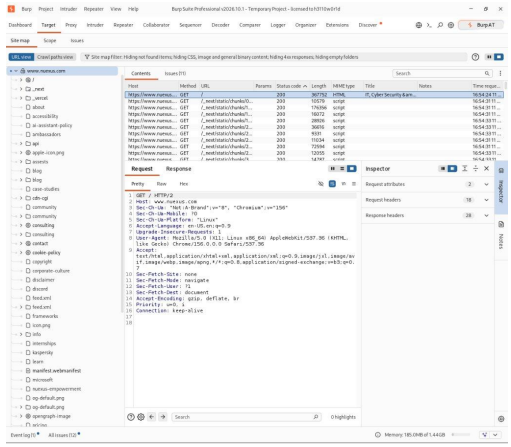


Figure 4.2: Hierarchical application endpoint modeling in Burp Target Site Map.

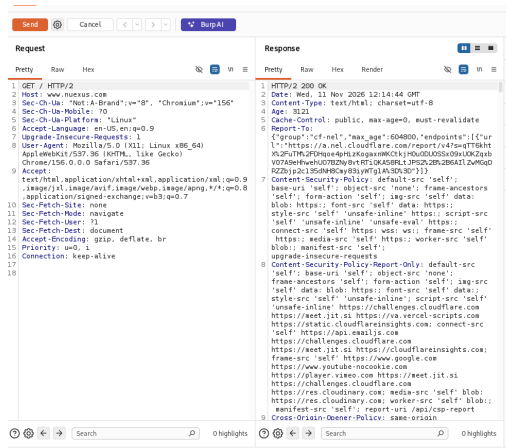


Figure 4.3: Manual baseline evaluation of GET / HTTP/2 request and response in Burp Repeater.

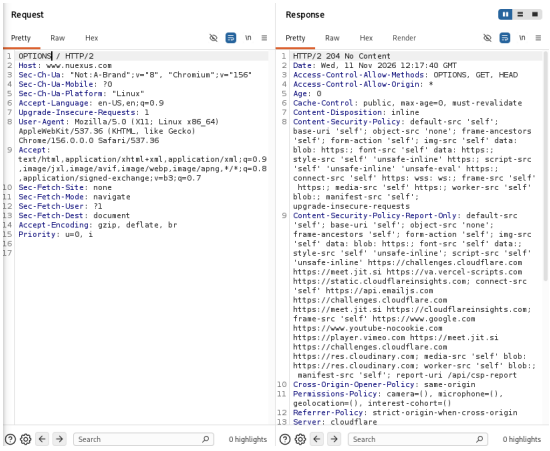


*Figure 4.4: Verb tampering via OPTIONS request uncovering permissive wildcard CORS (Access-Control-Allow-Origin: *).*

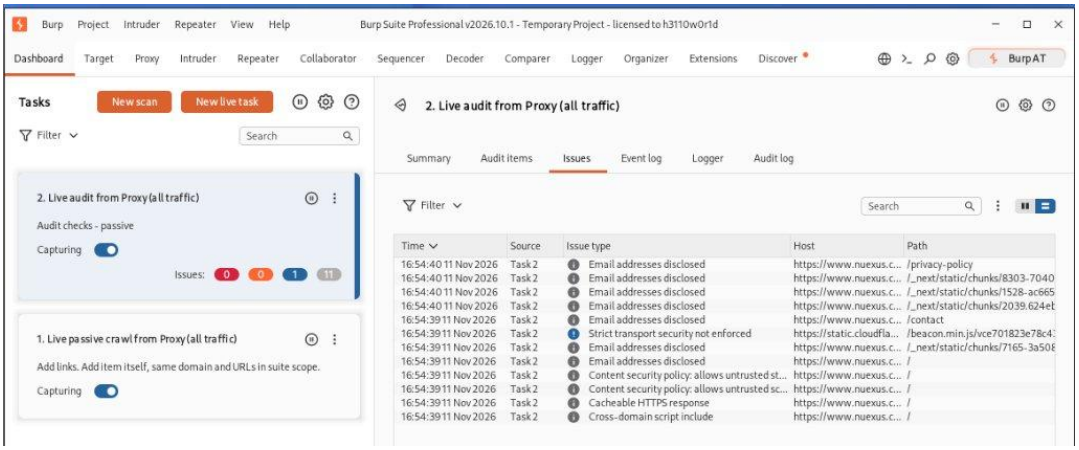


Figure 4.5: Burp Dashboard issue activity detailing 12 passive vulnerabilities.

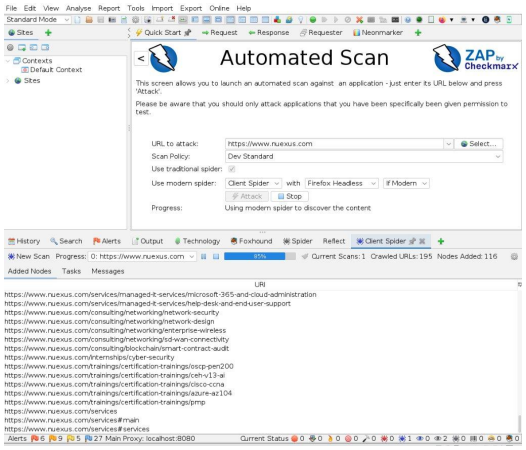


Figure 4.6: OWASP ZAP Automated Scan utilizing headless Firefox AJAX spider across 195 URLs.

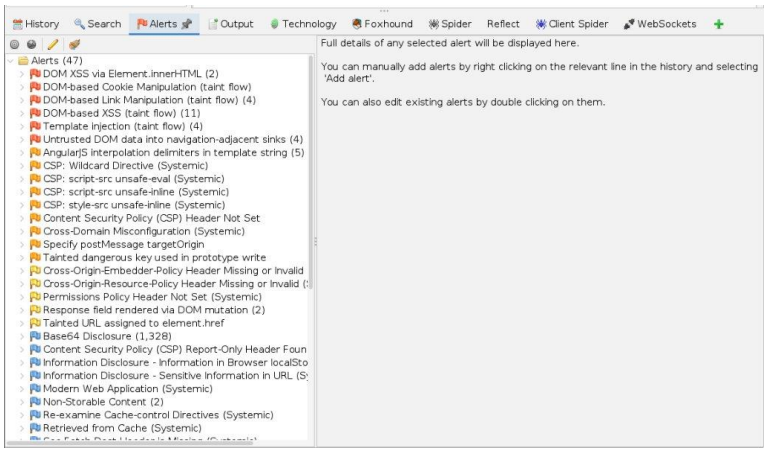


Figure 4.7: OWASP ZAP Alerts tree displaying 47 total vulnerabilities (DOM XSS, taint flows, CSP).

6. Strategic Hardening Recommendations

• **Harden Content Security Policy:** Remove 'unsafe-inline' and 'unsafe-eval' from Content-Security-Policy; adopt cryptographic nonces.

• **Restrict CORS Origin Directives:** Replace wildcard 'Access-Control-Allow-Origin: *' with an explicit whitelist of trusted frontend domains.

• **Sanitize Client DOM Sinks:** Refactor React/Next.js components to avoid direct assignment to Element.innerHTML (use DOMPurify or textContent).

• **Remediate Origin SSL Certificates:** Resolve HTTP 526 origin errors on api.nuexus.com, assessments.nuexus.com, and recruit.nuexus.com.

• **Apply Robots Noindex Headers:** Add 'X-Robots-Tag: noindex' to /playbooks/ and staging portals to prevent public search engine disclosure.